

INSTITUTO DE EDUCACIÓN SUPERIOR TECNOLÓGICO PÚBLICO
PROGRAMA DE ESTUDIOS: ARQUITECTURA DE PLATAFORMAS Y SERVICIOS DE TI

INFORME TÉCNICO DE APRENDIZAJE – SESIÓN DE CLASE
SEGURIDAD FÍSICA Y LÓGICA EN UN DATA CENTER
CASO PRÁCTICO INTEGRAL Y MAPA CONCEPTUAL INFOGRÁFICO

Aplicación de Estándares Internacionales: ANSI/TIA-942 (Tier III) e ISO/IEC 27001

DOCENTE:	Prof. Javier Eduardo Jaramillo Atoche
INTEGRANTES:	• Gerson Misael Pintado Huamán • Manuel Danilo López Garay • Mariana Juliet Clavijo Pinzón • Pedro Miguel Aguilar Flores • Dayron Antonio Urbina Zapata
SEDE Y AÑO:	Paíta, Piura – Ciclo Lectivo 2026

ACTIVIDAD 1: CASO PRÁCTICO DE SEGURIDAD FÍSICA Y LÓGICA EN UN DATA CENTER

1.1 Presentación de la Empresa: «FinanSur Data Cloud S.A.C.»

«FinanSur Data Cloud S.A.C.» es un centro de procesamiento de datos y hosting corporativo ubicado en la provincia de Paita. Administra una infraestructura crítica compuesta por 10 gabinetes (racks) de alta densidad, alojando bases de datos transaccionales, pasarelas de pago electrónico y sistemas de facturación de entidades financieras, cooperativas de ahorro y empresas agroexportadoras de la región.

Por la naturaleza de sus operaciones, la empresa procesa diariamente más de 85,000 transacciones bancarias y comerciales. No obstante, una reciente auditoría y una serie de contingencias pusieron en evidencia que la infraestructura presentaba graves deficiencias de seguridad tanto física como lógica.

1.2 Descripción del Incidente Real y Problemática Operativa

El incidente detonante ocurrió el pasado 14 de agosto a las 11:20 a.m., originado por un apagón en el alimentador eléctrico industrial de la zona. La cadena de fallos se produjo en tres etapas críticas:

- **1. Falla Eléctrica y Colapso Térmico:** El banco de UPS monofásicos de la sala técnica, cuyas baterías no habían recibido mantenimiento preventivo en 18 meses, colapsó en apenas 7 minutos. Por su parte, el grupo electrógeno diésel exterior no arrancó de forma automática debido a que el conmutador de transferencia (ATS) había quedado en posición manual tras una revisión técnica previa. La sala quedó sin suministro y los aires acondicionados split domésticos se apagaron. En solo 25 minutos, la temperatura ambiente subió de 21°C a 39°C, activando el apagado de emergencia de los procesadores por sobrecalentamiento.
- **2. Violación del Perímetro Físico y Accesos Indevidos:** Para acelerar la ventilación de la sala, los operadores abrieron de par en par la única puerta de acceso y colocaron ventiladores convencionales de pedestal. En medio de la confusión, personal de limpieza y proveedores externos de mensajería ingresaron a la sala técnica sin portar credencial, sin registro de bitácora y con libre acceso visual y físico frente a los racks descubiertos.
- **3. Intrusión Lógica y Ejecución de Malware en Servidores:** Al reanudarse la energía, uno de los servidores de bases de datos reportó un consumo anormal del 100% de CPU y tráfico inusual hacia una IP externa. El análisis forense determinó que un ciberdelincuente aprovechó que el puerto de escritorio remoto RDP (3389) estaba expuesto a Internet sin VPN ni autenticación multifactor (MFA), ejecutando un ataque de diccionario sobre la cuenta genérica «Administrador» e inyectando un script malicioso en la memoria.
- **4. Impacto Económico y de Reputación:** La caída del servicio se prolongó por 6 horas y media, provocando el bloqueo de transacciones comerciales, penalidades contractuales por S/. 48,000 y el reclamo formal de dos entidades bancarias socias.

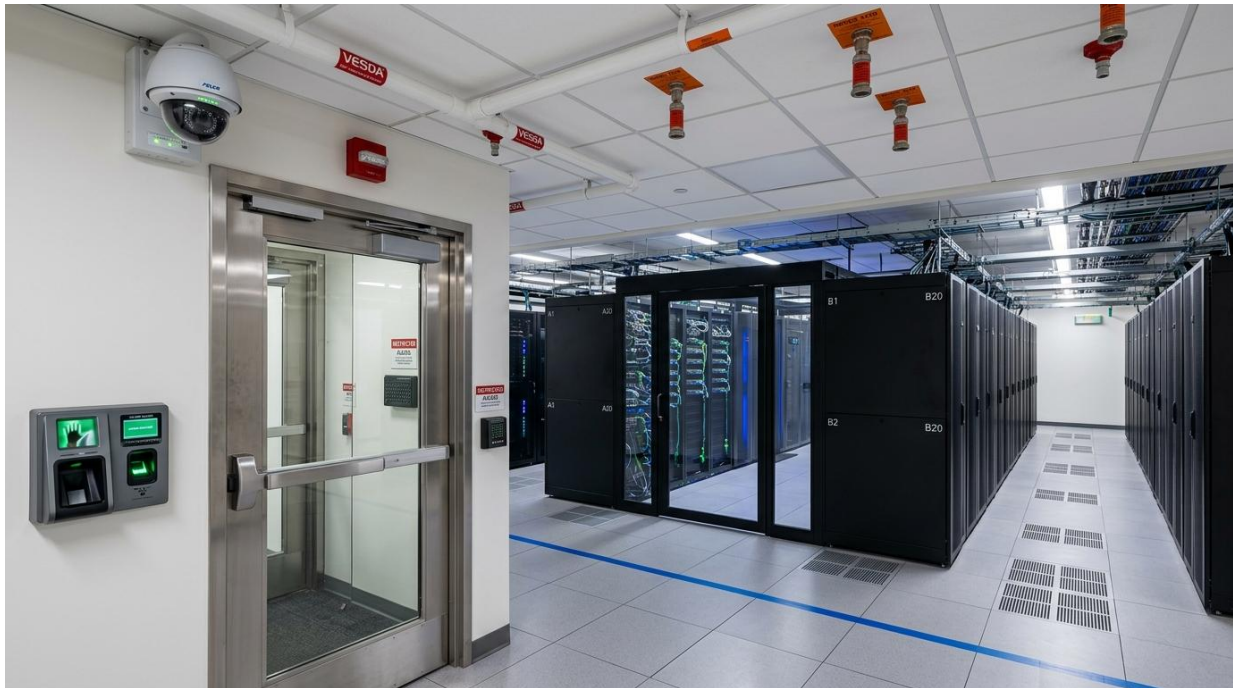


Figura 1: Diseño e infraestructura de Seguridad Física – Control de acceso en esclusa (Mantrap), biometría, sensores VESDA, Novec 1230 y confinamiento de pasillo frío.

1.3 Cuestionario de Análisis del Caso Práctico

[Cuestionario] Pregunta 1: ¿Cuáles fueron las principales fallas de seguridad física identificadas?

Respuesta: 1) Control de acceso precario (puerta con chapa simple sin esclusa de seguridad Mantrap ni biometría); 2) Inexistencia de bitácora digital de visitas; 3) Climatización doméstica inadecuada (equipos split sin control de humedad ni redundancia); 4) Suministro eléctrico frágil (UPS sin autonomía certificada, conmutador ATS trabado en manual); y 5) Rociadores de agua en sala TI con riesgo de destrucción de equipos.

[Cuestionario] Pregunta 2: ¿Cuáles fueron las principales brechas de seguridad lógica encontradas?

Respuesta: 1) Red plana no segmentada (los servidores compartían el mismo dominio de difusión que las computadoras administrativas y el WiFi); 2) Exposición directa de puertos críticos (RDP 3389) hacia la Internet pública sin túnel VPN; 3) Uso de cuentas compartidas genéricas («Administrador»); 4) Carencia de autenticación de doble factor (MFA); 5) Inexistencia de copias de seguridad inmutables contra Ransomware; y 6) Falta de monitoreo SIEM para detección de anomalías.

[Cuestionario] Pregunta 3: ¿Qué marcos y normas internacionales deben normar la solución?

Respuesta: Se fundamenta en dos normas globales: 1) ANSI/TIA-942 (Estándar de Infraestructura de Telecomunicaciones para Data Centers), adoptando el nivel Tier III con mantenimiento concurrente, rutas eléctricas redundantes y equipos N+1; y 2) ISO/IEC 27001 (Sistema de Gestión de Seguridad de la Información), implementando los controles del Anexo A para seguridad física del entorno (A.7) y seguridad operacional y de redes (A.8).



Figura 2: Centro de Operaciones de Seguridad (SOC) – Monitoreo de Firewall NGFW, segmentación de VLANs, detección de intrusos IDS/IPS y cifrado activo AES-256.

1.4 Plan Integral de Soluciones Técnicas Propuestas

[EJE FÍSICO] A. Soluciones en Seguridad Física (Instalaciones y Hardware):

- **1. Esclusa de Seguridad Interbloqueada (Mantrap) y Biometría:** Instalación de un sistema de doble puerta electrónica donde la segunda puerta solo abre si la primera está completamente cerrada. El acceso exige tarjeta RFID cifrada y lector biométrico (huella dactilar y reconocimiento facial), con registro digital automático de fecha, hora y usuario.
- **2. Climatización de Precisión con Confinamiento de Pasillos:** Reemplazo de los splits por unidades de aire de precisión en esquema redundante N+1. Se confina el pasillo frío para mantener la temperatura entre 18°C y 22°C y la humedad entre 40% y 60%, con sensores de alarma por inundación bajo el piso técnico.
- **3. Detección Temprana (VESDA) y Gas Limpio (Novec 1230):** Eliminación de rociadores de agua en la sala técnica. Se instala un sistema de detección temprana por aspiración de humo (VESDA) y extinción automática mediante gas limpio Novec 1230 o FM-200, que sofoca el fuego absorbiendo el calor sin dejar residuos ni conducir electricidad.
- **4. Redundancia Eléctrica Certificada Tier III:** Doble acometida eléctrica (Rutas A y B), banco de UPS modular trifásico de doble conversión con 45 minutos de autonomía garantizada y conmutador de transferencia automática (ATS) conectado al generador diésel con prueba de encendido semanal programada.
- **5. Videovigilancia CCTV HD con Visión Infrarroja 24/7:** Cámaras domo IP con sensor de movimiento y visión nocturna en pasillos y racks, con retención mínima de grabaciones por 90 días en almacenamiento protegido.

[EJE LÓGICO] B. Soluciones en Seguridad Lógica (Redes, Sistemas y Datos):

- **1. Segmentación de Redes (VLANs / DMZ) y Firewall NGFW:** Despliegue de un Firewall de Nueva Generación en clúster activo-pasivo. Se segmenta la infraestructura en VLANs independientes (Gestión, Servidores BD, Aplicaciones DMZ y Usuarios), aplicando una política de denegación por defecto (Drop all by default).

- **2. Autenticación Multifactor (MFA/2FA) y Control RBAC:** Exigencia estricta de token de seguridad de segundo factor (MFA) para todo acceso a servidores e interfaces administrativas (SSH, RDP, consolas web). Se aplica el principio de menor privilegio (RBAC) con credenciales personales intransferibles.
- **3. Acceso Remoto Seguro Exclusivo por VPN Cifrada:** Cierre total de los puertos de gestión hacia la red pública Internet. El soporte técnico a distancia se realiza únicamente a través de túneles VPN SSL/IPsec con cifrado AES-256.
- **4. Detección de Intrusos (IDS/IPS) y Correlación SIEM:** Implementación de firmas de detección y prevención de intrusos (IDS/IPS) para bloquear escaneos de puertos y ataques web en tiempo real. Los registros de auditoría se centralizan en una plataforma SIEM con alertas 24/7.
- **5. Estrategia de Copias de Seguridad 3-2-1 Inmutables:** 3 copias de los datos críticos, en 2 soportes diferentes (almacenamiento local SAN y repositorio en la nube cifrado), con 1 copia fuera de línea e inmutable (WORM - Write Once, Read Many), garantizando la recuperación íntegra ante Ransomware.

1.5 Matriz de Control de Riesgos y Resultados

Vulnerabilidad Detectada	Control Físico Aplicado	Control Lógico Aplicado	Resultado e Impacto
Ingreso no autorizado de personas a la sala	Esclusa Mantrap con biometría dactilar/facial y CCTV 24/7.	Bloqueo automático de sesiones inactivas y log en SIEM.	Cero ingresos indebidos; registro del 100% de accesos.
Corte eléctrico e interrupción del servicio	UPS modular trifásico N+1 y generador diésel con ATS automático.	Scripts de apagado ordenado automatizado si se agota la batería.	Disponibilidad 99.98% (SLA cumplido sin caídas no planeadas).
Ataque de fuerza bruta por puerto RDP	Cerradura de seguridad en puertas frontales y posteriores de racks.	Firewall NGFW, cierre de puertos, VPN obligatoria y MFA activo.	Bloqueo total de conexiones directas; neutralización de intrusiones.
Riesgo sobrecalentamiento incendio	Aire de precisión N+1 pasillo frío y extinción por gas Novec 1230.	Monitoreo de temperatura por SNMP con alertas automáticas (SMS/Mail).	Preservación íntegra del hardware ante emergencias térmicas.

ACTIVIDAD 2: MAPA CONCEPTUAL DEL TEMA

2.1 Representación Gráfica Infográfica del Mapa Conceptual

A continuación se presenta el mapa conceptual en formato infográfico de alta definición, diseñado para ilustrar de forma clara, moderna y jerárquica la articulación de la Seguridad Física y de la Seguridad Lógica bajo el marco integral de protección de Centros de Datos:

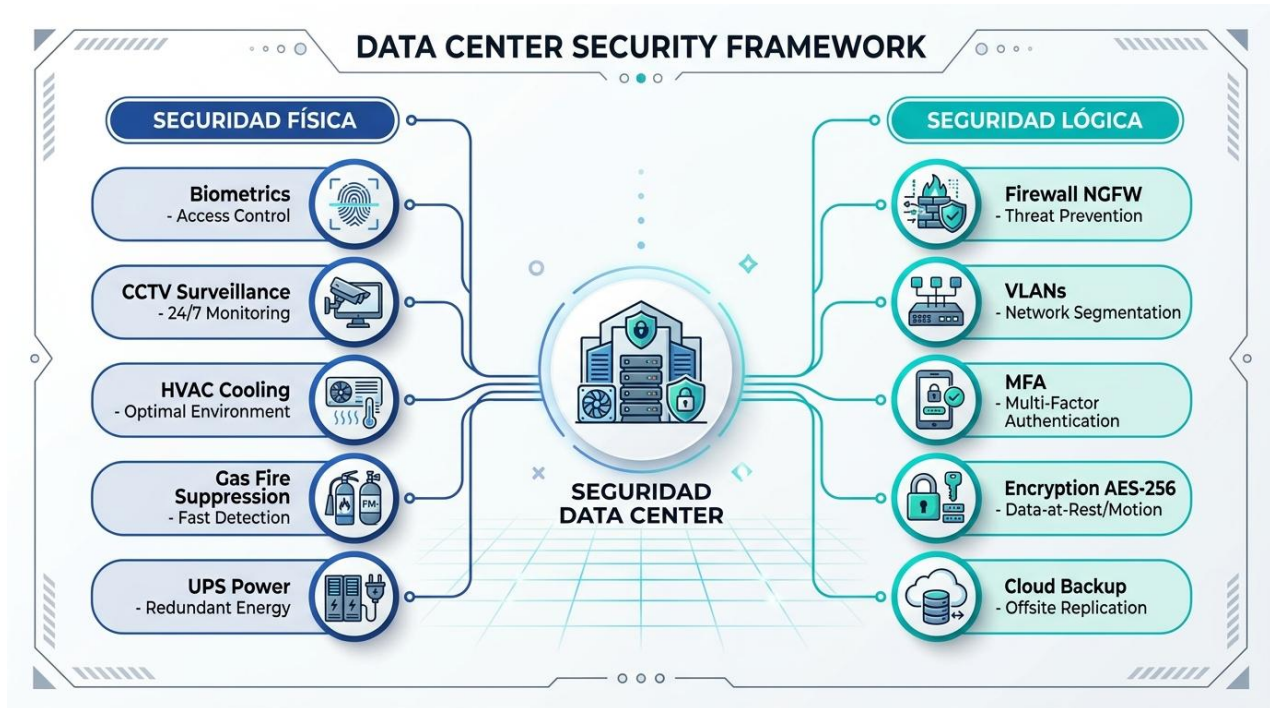


Figura 3: Mapa Conceptual Infográfico de Seguridad Física y Lógica en un Data Center (Marco Integral CID – ISO/IEC 27001 y ANSI/TIA-942 Tier III).

2.2 Estructura Jerárquica y Desglose por Niveles

El mapa conceptual se articula a través de cuatro niveles jerárquicos que interconectan la teoría con la práctica operativa:

- **Nivel 1 – Núcleo Conceptual::** SEGURIDAD EN EL DATA CENTER. Representa el objetivo fundamental: salvaguardar los activos de hardware, software y comunicaciones garantizando la tríada CID (Confidencialidad, Integridad y Disponibilidad).
- **Nivel 2 – Grandes Dimensiones::** Se bifurca en dos ramas de igual criticidad: 1) SEGURIDAD FÍSICA (protección de activos tangibles, salas, accesos y factores ambientales) y 2) SEGURIDAD LÓGICA (protección de activos virtuales, redes, sistemas y datos contra ataques digitales).
- **Nivel 3A – Pilares Físicos::** Comprende cinco componentes de protección física: 1) Biometría y control perimetral; 2) Vigilancia CCTV 24/7; 3) Climatización HVAC de precisión; 4) Extinción por gas limpio; y 5) Respaldo eléctrico continuo.
- **Nivel 3B – Pilares Lógicos::** Comprende cinco componentes de protección lógica: 1) Firewall NGFW perimetral; 2) Segmentación por VLANs; 3) Autenticación Multifactor (MFA); 4) Cifrado integral AES-256; y 5) Copias de seguridad en la nube (Cloud Backup).
- **Nivel 4 – Mecanismos Tecnológicos::** Implementa controles específicos como esclusas Mantrap, sensores VESDA, gas Novec 1230, UPS modular trifásico, ATS automático, políticas Drop All, tokens MFA, VPN IPsec y almacenamiento inmutable WORM.

2.3 Glosario Técnico de Términos del Mapa Conceptual

Esclusa (Mantrap)	Sistema de control de acceso físico con dos puertas interbloqueadas donde una no puede abrirse si la otra no está totalmente cerrada.
VESDA	Sistema de detección de humo por aspiración de muy alta sensibilidad que detecta partículas microscópicas antes de que aparezca llama abierta.
Novec 1230 / FM-200	Gases limpios de extinción que sofocan el conato de fuego absorbiendo el calor sin dejar residuos, sin ser conductores de electricidad y sin dañar la electrónica.
Conmutador ATS	Interruptor de transferencia automática que detecta la caída de la energía pública y enciende el generador diésel transfiriendo la carga sin intervención humana.
Firewall NGFW	Cortafuegos de nueva generación que analiza el tráfico a nivel de aplicación (Capa 7), integrando antivirus, prevención de intrusos (IPS) y filtrado web.
Autenticación MFA / 2FA	Mecanismo de seguridad que exige al menos dos factores distintos para validar la identidad (algo que sabe: contraseña, y algo que tiene: token/código).
Inmutabilidad WORM	Propiedad de almacenamiento (Write Once, Read Many) que impide que una copia de respaldo sea modificada, sobreescrita o borrada por un ataque de Ransomware.

CONCLUSIONES Y RECOMENDACIONES GENERALES

- **Indisociabilidad de Ambas Dimensiones:** La seguridad física y la seguridad lógica son dos caras de la misma moneda. Blindar la red con firewalls y cifrado resulta estéril si cualquier persona puede ingresar a la sala y desconectar un servidor; de igual modo, un centro acorazado con biometría es inútil si los puertos de administración están abiertos a Internet sin protección.
- **Criterio de Redundancia y Continuidad (Tier III):** En centros de cómputo que manejan operaciones críticas, no debe existir ningún punto único de falla (SPOF - Single Point of Failure). La duplicidad de rutas eléctricas (UPS y generadores) y la climatización N+1 son requisitos indispensables para cumplir con los acuerdos de nivel de servicio (SLA).
- **Evolución hacia la Inmutabilidad de los Datos:** Frente al crecimiento de amenazas avanzadas como el Ransomware corporativo, las copias de seguridad tradicionales son insuficientes. Es mandatorio implementar esquemas de respaldo inmutables (WORM) y almacenamiento fuera de línea bajo la regla 3-2-1.
- **Mantenimiento y Auditoría Periódica:** La seguridad de un Data Center no concluye con la compra de equipos; exige pruebas periódicas de arranque de generadores, simulacros de contingencia, revisión semanal de bitácoras de acceso y auditorías continuas bajo la norma ISO/IEC 27001.

— FIN DEL INFORME TÉCNICO —